Enforcing The Chinese Wall Security Policy in Security-Enhanced Linux

by

Calum Cardownie

In partial fulfilment of the
requirements for the degree of
Bachelor of Science
in
CS408: Individual Project

Experimentation-Based with Significant Software Development

Department of
Computer and Information Sciences

March 2026

Abstract

The abstract is a bird's eye view of the project. It should not exceed one page. Mention the scope and objectives of the project, the methodology used,the main findings, and significance of your results.

Acknowledgements

I would like to thank

Contents

1 Introduction **1**
1.1 Background . . . 1
1.2 Project Aim . . . 1
1.3 Research Question & Objectives . . . 2
1.4 Report Format . . . 2

2 Literature Review **3**
2.1 The Chinese Wall Policy . . . 3
2.1.1 The Brewer-Nash Model . . . 3
2.1.2 Intricacies of the Chinese Wall . . . 3
2.2 Chinese Walls in Adjacent Systems . . . 4
2.2.1 Foley's Unix Model . . . 4
2.2.2 Cloud Computing . . . 5
2.2.3 Workflow Management . . . 6
2.2.4 Financial Institutions . . . 7
2.3 Security-Enhanced Linux . . . 7
2.3.1 Mandatory Access Control System . . . 7
2.3.2 Security Architecture . . . 8
2.3.3 Policy Module System . . . 9
2.3.4 MLS In SELinux . . . 9
2.4 Origin and Role of Security-Enhanced Linux . . . 10
2.4.1 The NSA's Creation of SELinux . . . 10
2.4.2 Inclusion of SELinux in the mainline Linux kernel . . . 10
2.4.3 Red Hat Enterprise Linux . . . 10

3 Specification **12**
3.1 Methodology . . . 12
3.1.1 Agile . . . 12
3.2 Project Stages . . . 12
3.2.1 Understanding SELinux & Brewer-Nash . . . 12
3.2.2 Static Chinese Wall . . . 12
3.2.3 Dynamic Chinese Wall . . . 13
3.2.4 Testing & Evaluation . . . 13
3.3 Analysis . . . 13
3.4 Contingency Plan . . . 14
3.5 Requirements . . . 14

4 Design **16**
4.1 Policy Design . . . 16
4.1.1 Object Policy Modules . . . 16
4.1.2 Subject Policy Modules . . . 16
4.1.3 CWD Policy Module . . . 17
4.2 System Design . . . 17
4.2.1 Tailing the Audit Daemon . . . 17
4.2.2 Subject Label Alteration at Runtime . . . 18

4.2.3 Flowchart . . . 18
4.2.4 UML Diagram . . . 18
4.3 Assisting Programs . . . 19
4.3.1 cwalld-init . . . 19
4.3.2 cwalld-tail . . . 19

5 Implementation **20**
5.1 Virtual SELinux Environment . . . 20
5.2 Technology Selection . . . 20
5.2.1 Language . . . 20
5.2.2 Packages . . . 21
5.3 Version Control . . . 21
5.4 Policy Modules . . . 22
5.4.1 Object PM Implementation . . . 22
5.4.2 Subject PM Implementation . . . 22
5.4.3 CWD PM Implementation . . . 23
5.5 Internal Packages . . . 23
5.5.1 SEnv (Security-Enhanced env) . . . 23
5.5.2 Sleuth . . . 24
5.5.3 Subject . . . 26
5.5.4 Decorator and Logger . . . 26

6 Verification & Validation **27**
6.1 Testing & Verification . . . 27
6.1.1 Integration Testing . . . 27
6.1.2 Unit Testing . . . 27
6.1.3 Benchmarking . . . 27
6.2 Validation . . . 28

7 Results & Evaluation **29**
7.1 Evaluation Process . . . 29
7.2 Results of Evaluation . . . 29
7.3 Returning to the Objectives . . . 30
7.3.1 Research Question . . . 30
7.3.2 Objective 1.3.1 . . . 30
7.3.3 Objective 1.3.2 . . . 30
7.3.4 Objective 1.3.3 . . . 30

8 Discussion & Reflection **31**
8.1 Interpreting the Results . . . 31
8.2 Reflection . . . 31
8.3 Challenges . . . 31
8.4 Limitations . . . 31
8.5 Future Work . . . 32

9 Conclusion **33**

A Appendix **36**

A.1 cwalld design 36
A.2 Red Hat 38
A.3 Auditd logs 39
A.4 Policy Modules 40

1 Introduction

1.1 Background

"The more you know, the less you can share" serves the basis for the Chinese Wall Model. The policy deems that a subject (a daemon/process) in the system shall lose its read/write privileges as it gathers more information [1]. Conflict of Interest (`CoI`) classes are used to dictate restrictions, with the goal of the policy to stop the subject from sharing sensitive information between objects (files) that are conflicting with each-other. The dynamic nature of the Chinese Wall makes it a specifically intriguing security policy, in stark contrast from typical static security policies.

Security-Enhanced Linux (SELinux) is a well-known solution to all sorts of security concerns threatening servers and personal devices. SELinux implementing *Red Hat* have solidified themselves as the industry choice for secure hosting solutions, being a leading operating system used by over 90% of Fortune 500 companies for its quality privacy guarantee [2]. The flexible set of security controls brought by SELinux brings great freedom to development of specialised policies.

1.2 Project Aim

The project aims to prove the possibility of the Chinese Wall (Brewer-Nash) Model in SELinux, primarily by implementing an interpretation of the policy, leveraging the *Mandatory Access Control* (MAC) system introduced by SELinux.

The Chinese Wall has received a noticeable lack of attention in the space surrounding SELinux, considering its notoriety in surrounding areas. While providing an implementation for SELinux, this report delves into the use cases of this specific policy, where it has succeeded in the past, and what its inclusion in SELinux facilitates.

Previous research into both Chinese Wall use cases and SELinux was factored in the design process, along with hands on experimentation and prototyping of different solutions. The development of the Chinese Wall in SELinux aims to open possibilities of dynamic policies in the otherwise static SELinux, and potentially lead the way in future security solutions.

To enforce this policy model in SELinux, policy modules must be compiled into the kernel via the security server and work in tandem with the Chinese Wall Daemon, developed to be capable of enforcing dynamic label alterations to monitored subjects. A lattice based system is used to transition

subject labels based on their read and write history accordingly, which should suffice to handle all cases of the Chinese Wall. Finally, this allows the SELinux Access Vector Cache (AVC) to handle the restrictions on a kernel level, successfully locking the system down to `CoI` breaches once intervened.

1.3 Research Question & Objectives

Research Question:

Can SELinux's Mandatory Access Control system facilitate the dynamic Chinese Wall Policy?

Objectives to Achieve:

1.3.1 Develop a set of Policy Modules, capable of enforcing a static Chinese Wall on subjects confined by SELinux.

1.3.2 Implement a method of dynamically altering labels, allowing SELinux to enforce the Chinese Wall policy.

1.3.3 Conclude why development in this area may be lacklustre, by analysing the difficulties and limitations that arose with development.

1.4 Report Format

The report is structured in a sequence appropriate to the process undertook addressing this challenge. Section 2 introduces background knowledge and similar work to set the basis for the project. Section 3 summarises the methodology and order of approach to the project. Section 4 details design intricacies, and section 5 goes into depth of implementation to these designs. Section 6 will demonstrate testing and validation, and section 7 will cover the results. Sections 8 will include a discussion and reflection, and finally section 9 will conclude the paper.

2 Literature Review

2.1 The Chinese Wall Policy

2.1.1 The Brewer-Nash Model

The Chinese Wall Model - or Brewer-Nash Model - is a security model that aims to prevent information flow between datasets that are in *conflicts of interest* (`CoI`) [1]. The Brewer-Nash Model provides a mathematical format that is based on the larger Chinese Wall policy. As opposed to the classic multi-level security Bell LaPadula model, which enforces *"no read up, no write down"* [3], the Chinese Wall model allows for information flow freely until a subject attempts to read from a `CoI` object. Upon this access, the system shall dynamically revoke their write permissions to other objects in the `CoI` group, creating a "wall" in-between them. Consider the following scenario:

A data server stores information on Bank A and B, and Tech Company A and B. These are in a `CoI` relation with their respective counterparts. If a user approaches the dataset, they are initially able to access any object. As far as the system is concerned, this user is free as they have no prior knowledge of either companies. Suppose the user has read from Bank A, the situation develops - the user now possesses information that, deemed by the Chinese Wall, should not be allowed to reach Bank B, as they in a `CoI` relation with Bank A. The Wall revokes the write access from the user in regard to Bank B. Now information *cannot* flow from Bank A to B. The system is constructed to definitively prevent this leakage scenario. It should also be noted that once information from Bank A is read, it cannot be shared to Tech Company A or B. In that scenario, a different subject could read from Tech Company A and write to Bank B, as they are not in conflict, exploiting the rules of the Chinese Wall.

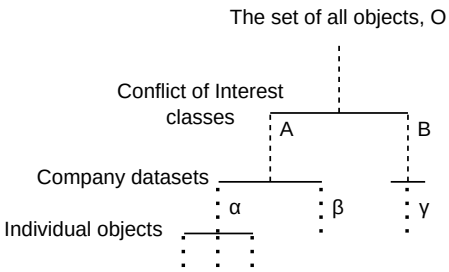


Figure 1: The composition of objects

2.1.2 Intricacies of the Chinese Wall

Brewer & Nash's rules demonstrated the Chinese Wall as more as a mathematical concept than a policy. They broke it down into the following rules, influenced by Bell-LaPadula:

- **Simple Security Property**: Subject `S` can read object `O` only if `O` is in the same Company

Dataset (CD) as an object already read by S, or if O's CD is in a different CoI group from all CDs of objects already read by S.

- ***-Security Property**: Subject S can write to an object O only if S can read O **and** all objects O' read by S are in the same CD as O.

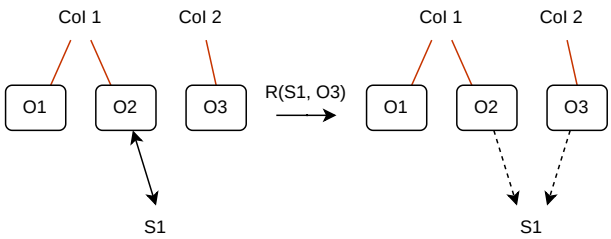


Figure 2: Demonstration of the *-property

Note in Figure 2, where a full line represents read/write access and a dotted line represents read access; Once a read is performed on O3, the **-property* dictates that subject S1 must lose its write access to O2.

The Brewer-Nash model suffers from a lack of clarity in some areas, leaving readers split on interpretations of certain definitions in the paper. The *-property for one, leaves it unclear if write access implies read access. As such, this report will outline a clear understanding the Chinese Wall and follow that definition.

After the Brewer-Nash model was communicated, another paper was published once again by Brewer & Nash, but also T.Y. Lin, who presented them with potential improvements on their model after their original paper, leading to the *Aggressive Chinese Wall* [4]. This idea, trying to disprove the assumption that the conflict of interest is an equivalent relation, has since been accepted into the mainstream.

2.2 Chinese Walls in Adjacent Systems

To understand the effect that a new Chinese Wall can have, and how measures could be taken to implement it, other ventures in adjacent systems should be investigated and evaluated. Unix, Cloud, Workflow Management & Finance will be discussed in the following.

2.2.1 Foley's Unix Model

A Chinese Wall model implementation was attempted in standard Unix, leveraging its *Discretionary Access Control* (DAC) security system also adopted by Linux and macOS. The 1997 Unix proof by S.N. Foley built upon T.Y. Lin's Aggressive Chinese Wall Model, illustrating the possibility of its creation in with DAC [5]. The Unix proof features a CoI matrix, detailing a non-transitive version

of the `CoI` relations. Foley's concept focused on the restriction of users, preventing a user of the computer from spreading information enforced via their user ID and group ID. DAC is defined such that objects and their privileges are managed by their creator, and the super-user can access and alter anything. DAC enforces based on the user ID and any groups with which they belong. While DAC brings about great flexibility, the models' reliance on ownership often leads to uncontrolled privilege propagation. It is known to be difficult to measure the security of the DAC model, and in some cases it is undecidable [6].

2.2.2 Cloud Computing

Chinese Walls have been implemented in Cloud Computing against various threat models. Cloud Computing involves many Virtual Machines (VMs) running on one core system, with the virtual machine monitor, or *hypervisor* acting as the delegating force of the computers' hardware to the VMs. Each VM is a separate Operating System (OS), meant to be completely independent of the other VMs on a machine.

sHype Hypervisor

The sHype mandatory access control system was added to the Xen hypervisor to defend against information sharing between VMs by R. Sailer et al [7]. The hypervisor prevents inter-VM communication by utilising kernel hooks, intercepting and evaluating every attempt to communicate across VMs. Whilst claiming to be a Chinese Wall, the sHype architecture does not truly capture the notion of Brewer & Nash's Model, instead focusing on static *"Chinese Wall types"*. Regardless, sHype does successfully prevent against `CoI` leakages, in the case of insider activities or inter-VM attacks.

Chinese Wall Central Management System

Inter-VM attacks can happen if a VM on the system is breached, and can allow a targeted attack on another VM, even a compromised hypervisor. To eliminate the possibility of inter-VM attacks from competitors, a different Chinese Wall security model was implemented. The CWCMS, operating above the Kernel-based Virtual Machine[1] level via installed control agents, with a sole focus of actively preventing `CoI` breaches was designed by Tsai et al [8]. Once a VM in a `CoI` group is

[1] KVM allows the Linux kernel to act as a hypervisor.

running on a physical host, the Wall prevents other VMs belonging to the same `CoI` group from being scheduled on the same machine in advance. This is a pre-arranged decision made by graph colouring, as opposed to sHype which simply attempts to deploy it on different systems until one is satisfactory. This effectively eliminates the risk of inter-VM attacks in these systems. Similar to sHype, CWCMS also lacks dynamic label profiling, resolving to a statically enforced, yet successful, policy model.

Security-Awareness VMs Management Scheme

Finally, a dynamic Wall was created in Yu et al's SVMS system [9]. SVMS aims to eliminate intrahost *side channel attacks*, where malicious users extract private information by reading from shared data caches on the host machine. Yu et al address this with two techniques: Preventing simultaneous execution, and a more unique advance with VM placement and migration solutions based on VM traces. These VM traces are accumulated by tracking the *aggressive conflict of interest relation* and *aggressive in ally with relation*, they create a dynamic policy model faithful to the Brewer-Nash model, proving that the rules meet the simple-security property and *-security property.

All models, while different, agree that the *Chinese Wall* for Cloud involves preventing conflicting resources from running at the same time. Whilst not exactly cohering to the Brewer-Nash model, they all manage to succeed in their endeavours to create a Chinese Wall.

2.2.3 Workflow Management

Beyond virtualized environments, the Chinese Wall model has also successfully been implemented in workflow management systems. *Workflow Management Systems* (WfMS) are intrinsically network-based applications, potentially hosting multiple conflicting company datasets. As such, a secure WfMS must implement security features, specifically targeting information confidentiality as a main point of effort. The Chinese Wall security model can be leveraged to prevent conflict of interest leakage in this environment. The authors proposed and implemented a *Chinese Wall Security Policy Specification Language* in Java [10]. The paper mentions that Role Based Access Control is unable to implement general cases of the Chinese Wall, as it has issues implementing the Brewer-Nash simple security property in dynamic contexts, supporting the premise that the dynamic nature of the Chinese Wall is difficult to implement with standard methods.

2.2.4 Financial Institutions

Chinese Walls serve as a pillar of compliance in the financial sector. The ethical policy, more commonly just referred as *The Wall* in finance, is a commonplace measure that should theoretically and practically prevent misuse of information leakage in banks [11] and other financial management firms. Thus, the Wall is more attuned to person-level restrictions as opposed to system-wide enforcement as is present in modern considerations of the Wall. While entirely different from modern systems, it helps to understand the origin of the Wall, and that it aimed to prevent `CoI` leakage of strictly confidential information.

2.3 Security-Enhanced Linux

Understanding the properties and behaviour of SELinux was key in approaching the project, thus, it is important to discuss the systems brought in place, and the solutions they approach.

2.3.1 Mandatory Access Control System

Security Enhanced Linux implements a Mandatory Access Control system, providing a policy-driven security layer extended beyond the classic DAC. Utilisation of labels - applied to both objects and subjects - and verbose policy modules provide the OS great freedom in restriction and enforcement. The *Security Context*, or *label* of an object/subject takes the form `user_u:role_r:type_t:s0` and can be viewed with the `-Z` flag when using `ls` or `ps`[2].

```
/home/testgrounds/objects ❯ ls -Zl | grep alpha_logs
-rw-rw-rw-. 1 cal cal unconfined_u:object_r:alpha_t:s0     28 Mar 20 00:24 alpha_logs
      Standard Unix DAC          SELinux MAC Security Context
```

Figure 3: Security Context of an object

The Security Context consists of the fields:

- **User** (`user_u`): Used to give the confine specific Linux users to a class, granting them simple privilege differences. Examples include `guest_u`, `user_u` or `staff_u`.
- **Role** (`role_r`): Used to confine users to roles, implementing role based access control.
- **Type** (`type_t`): Used to restrict subjects based on their domain type. The most specific field a policy can target.

[2] `ls` and `ps` are standard Unix commands to list objects and processes respectively.

- **Level** (`s0`): Used in Multi-Level Security (MLS) and Multi-Category Security (MCS) contexts to seperate subjects and objects based on classification / category. Often used to isolate VMs and containers from sharing access to the same resources.

A simple policy may be that an object of type `http_t` can only be operated on by a subject of type `apache_process` and prohibits `sshd_t`. This provides strong mitigation against broken access control damages, as subjects can only access objects that they are contained to by SELinux's security server. Were a subject hijacked, it is still only restricted to the domain it originally had on the system.

2.3.2 Security Architecture

Being based off of the Flux Advanced Security Kernel (FLASK) security architecture for flexible non-discretionary access controls [12], the architecture of SELinux is split into 2 main bodies:

- Policy enforcement via the Access Vector Cache.
- Policy decision-making via the Policy Repository and Security Server.

The AVC serves as the main denial body, instantly able to deny a process on a cache hit. On a cache miss, the kernel briefly blocks the process as the syscall is carried out and the AVC enforces the denial / allows the syscall [13].

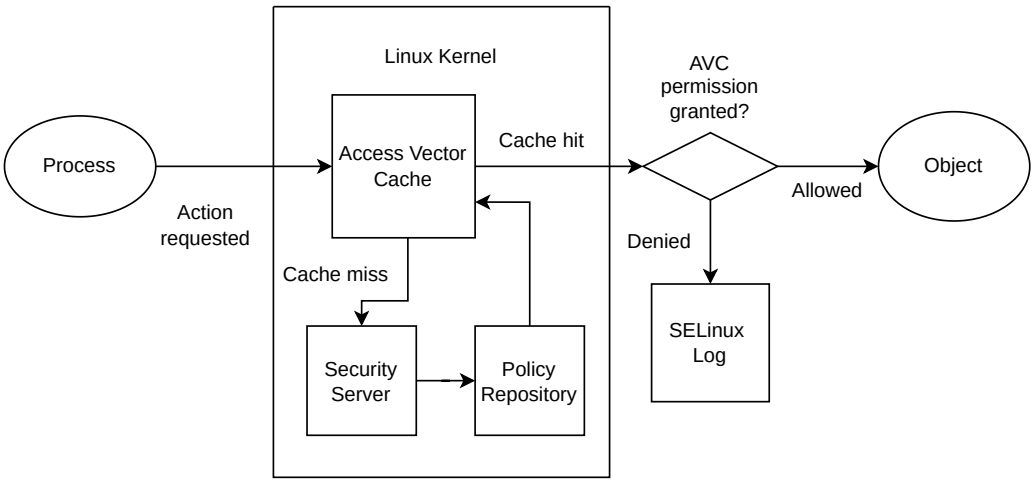


Figure 4: Primary SELinux Components

2.3.3 Policy Module System

The *policy modules* (PMs) that SELinux provides are solely controlled by the super-user. Red Hat 9 by default has 440 modules (verified on a fresh Red Hat 9.7 install), covering every domain in the system. The *policycoreutils* package introduces developer tools to install and alter PMs on the system, calling `sepolicy generate --init` from the command line generates boilerplate for the policy including:

- Type Enforcement *(.te)* file: Unique syntax notates dependencies and defines rules, introduced to restrict the new labels.
- File Contents *(.fc)* file: Details the file labeling rules for the policy.
- RPM Package Manager (RPM) Spec *(.spec)* file: Packages the policy to be installed into the kernel with RPM, including labelling, the interface file and associated man page of the policy.
- Interface *(.if)* file: Defines the interfaces for the types generated in the type enforcement file, allowing policies to reference each-other.
- Shell Script *(.sh)* file: A script to be run by the super-user to compile and install the policy module. Under the hood, various commands are executed, eventually calling *semodule -i* to complete installation.

Once installed, PMs are persistent, and restrict based on their domain while SELinux is in *Enforcing* mode. SElinux also supports a *Permissive* mode, where denials are simply logged and not enforced, integral for testing, but at the cost of risk in the system. The sepolicy generate command includes a permissive line that must be removed from each *.te* file for the same reason.

Compiling modules without the template from sepolicy generate, a policy module must be installed with `checkmodule`, `make -f /usr/share/selinux/devel/Makefile` & `semodule -i`.

2.3.4 MLS In SELinux

The *Bell-La Padula* model has previously be implemented in standard SELinux. It can be enabled and on reboot, a full filesystem relabel is applied according to their MLS clearance level (top-secret, confidential...). The implementation mainly utilises the level field to restrict them based on sub-sections within that range of confidentiality. It is a MAC policy like the Chinese Wall, but is entirely

static at runtime.

2.4 Origin and Role of Security-Enhanced Linux

2.4.1 The NSA's Creation of SELinux

SELinux is adopted by many distributions of Linux, including Red Hat Enterprise Linux (RHEL), Fedora and even mobile operating system giant Android. The origin of SELinux can be attributed to the *National Security Agency* (NSA)'s workings on a series of books called the Rainbow books - A series of Computer Security standards and guidelines by the United States Government. They published one and created a second (unpublished) book that included a formal SELinux model and associated evaluation evidence prototype. SELinux was a demonstration that mandatory access control was viable and could be added to the Linux kernel. The NSA, along with NAI Labs were responsibile for using FLASK to integrate MAC controls into the Linux kernel [14][15].

2.4.2 Inclusion of SELinux in the mainline Linux kernel

Linux, as an OS was able to adopt this because of its commitment to software freedom and ethical use of technology, originally being an open-source derivation from the Unix that was locked down by AT&T's IP. Linus Torvalds combined his Linux kernel with the GNU system tools by the GNU Project (Richard Stallman and various developers) to create GNU/Linux [16]. Linux was built under the *GNU General Public Licence*, dictating that all code in the system had to be free and accessible. This open-source philosophy was a key factor enabling SELinux's integration into the mainline kernel in the 2.6 series in December 2004 [17].

2.4.3 Red Hat Enterprise Linux

The impact of Linux is huge, with 85% of smartphones and 96% of top 1 million websites powered by the free OS [18] [19]. Tech Giant IBM produced RHEL has a 33% market share in worldwide operating systems [20] (See Appendix 9), no doubt because of their commitment to reliability, stability and security.

As one of many distributions of Linux, RHEL is unique as a subscription based distribution, with a target audience of companies expecting nothing less than the finest. SELinux is clearly a lucrative avenue for development, and the introduction of new and unique security policies could yield various

results.

3 Specification

3.1 Methodology

The decision to adhere to a methodology early in development helps set up consistent and satisfying progress over the life of the project. As this project was undertaken as a solo developer, the decision of methodology was not as crucial as a team setting. Still, the project lifecycle followed is more closely attuned to the agile principle.

3.1.1 Agile

Agile methodology focuses on multiple iterative stages, constantly evaluating the progress and direction of the project, and tuning decisions to reach the solution. As SELinux is a system with predefined capabilities and limitations, various different methods were used throughout to probe the boundaries and prototyping was updated accordingly. Experimentation in SELinux was carried out simultaneously alongside research, allowing accumulated insight to be backed by personal experience, and a more complete and satisfying solution.

This agile process was accompanied by a simple TUI kanban board, easily conveying the stage of the project as well as next steps and currently occupied tasks. This allowed for a more fulfilling lifecycle of an idea.

3.2 Project Stages

3.2.1 Understanding SELinux & Brewer-Nash

This stage encompassed both researching and experimentation the main topics. A VM was set up, that was used to deploy and test the product throughout the project. The boundaries of SELinux were to be tested, with different avenues being evaluated and logged. The complexities and nuances of Brewer-Nash were be studied; proving to be more complex than they seem at the first glance.

3.2.2 Static Chinese Wall

The first milestone of the project involved creating a static implementation of the Wall. This stretch aimed to prove that the SELinux type enforcement was verbose and specific enough to constrain a subject to specific allowances and denials. The phase was marked complete with the necessary policy

modules installed to restrict specific subjects from specific objects, mimicking the Chinese Wall & using simple test daemons to confirm its effectiveness.

3.2.3 Dynamic Chinese Wall

The longest stage, involved achievement of the dynamic Chinese Wall by way of creating the *Chinese Wall Daemon*, (*CWD/cwalld*) and its surrounding policy modules. This phase closely embodied the agile methodology, as the daemon was built step by step, ontop of the already working static wall policies.

3.2.4 Testing & Evaluation

This phase involved testing the constraints and abilities of the final product. Suitable testing measures were all be applied to effectively evaluate functionality and overall success of the project. The entire project journey was evaluated, and limitations of the end product were assessed.

3.3 Analysis

To enforce a dynamic security policy, some process must be constantly running to be capable of enforcing said dynamism. During experimentation on the boundaries of SELinux, it was resolved that the most effective way to leverage its MAC system was to change the type field of the security context on active subjects in the system. The user, role and level fields of the subjects/objects are not sufficient to enforce a security policy, as flexibly policy modules were unable to be compiled to enforce restrictions based on those fields.

Policy modules are unable to be added to the SELinux security server at runtime, as it requires a complete re-compile of the security server and kernel. This operation is capable of taking anywhere between 4 and 8 seconds - unrealistic at runtime for a background process. Thus, policy modules cannot not be compiled while the system is running.

Further experimentation on the properties of the type field of the label led to the philosophy that became the main premise of the CWD. Pre-compiled policy modules for all scenarios, and a daemon that would alter the labels of subjects at runtime, according to their history of operations and the Chinese Wall policy. This daemon also needed to be fully integrated into SELinux's system, running under its own `cwalld_t` type.

The alteration of subjects also required a brief termination of the subject, as the security context is granted upon startup, so changing the label would require a restart at runtime.

3.4 Contingency Plan

As this project is venturing into territory that was unknown, a contingency plan had to be produced, to ensure a rewarding outcome was still delivered if the primary goal was unreachable. The contingency plan for the CWD was made in the case of dynamic labels being unfeasable, and involved the CWD acting as an auditing daemon, auditing when breaches of the Chinese Wall had been detected, but not enforcing.

3.5 Requirements

Requirements specified early in the agile cycle follow the priority categories principle. Requirements are split into 4 categories:

- **Must** have - features that must be implemented to achieve the goal.
- **Should** have - features that should be implemented to develop the solution.
- **Could** have - features that could be implemented but would not be prioritised.
- **Won't** have - features that were considered but decided against.

These requirements were solidified after considering the required functionality of the product in depth. While the requirements were decided from the beginning, the means of which to complete them was left ambiguous, in line with agile structure.

Code	Requirement	Priority
FR1	`cwalld` must alter necessary configurations in the system before running.	Must
FR2	`cwalld` must monitor all operations made by subjects across a given directory.	Must
FR3	`cwalld` must make decisions based on subject label and object label aligned with the Chinese Wall policy.	Must
FR4	`cwalld` must alter the labels of subjects at upon call.	Must
FR5	`cwalld` must be accompanied by policy modules for objects.	Must
FR6	`cwalld` must be accompanied by policy modules for subjects.	Must
FR7	`cwalld` should be confined by SELinux with its own custom policy.	Should
FR8	`cwalld` should run as a service in the system with a service declaration file.	Should
FR9	`cwalld` should write all operations to a log.	Should
FR10	`cwalld` should include a binary to follow and display the log in real time.	Should
FR11	`cwalld` could automatically create necessary policy modules for its runtime.	Could
FR12	`cwalld` could automatically install necessary policy modules before running.	Could
FR13	`cwalld` could dynamically enforce the policy given a set of `CoI` classes as input.	Could
FR14	`cwalld` won't enforce the Chinese Wall policy system-wide.	Won't

Table 1: Functional Requirements

Code	Requirement	Priority
NFR1	`cwalld` shall solely be controlled by the super-user.	Must
NFR2	`cwalld` shall run as a daemon in user-space of the computer.	Should
NFR3	`cwalld` shall be written with structural, intentional and idiomatic code.	Should
NFR4	`cwalld` shall be a good unix citizen, following classic system conventions.	Should
NFR5	`cwalld` shall function as intended across both x86 and ARM architecture.	Should
NFR6	`cwalld` shall act atomically, ensuring the Chinese Wall is instantaneous.	Won't

Table 2: Non-Functional Requirements

4 Design

4.1 Policy Design

To demonstrate the Chinese Wall Model in SELinux, the minimum amount of labels necessary to capture all use cases of the wall was designed. The model was designed such that there would be 3 object classes, 2 of which were in a `CoI` relation, and one which was not.

4.1.1 Object Policy Modules

A unique PM had to be installed for each different `CoI` type. The object PMs were simple, as they only needed to introduce the type to the system. This allowed the subject PMs to be reference the objects. The following types were to be introduced:

- `alpha_t`
- `beta_t`
- `gamma_t`
- `sanitised_t`

4.1.2 Subject Policy Modules

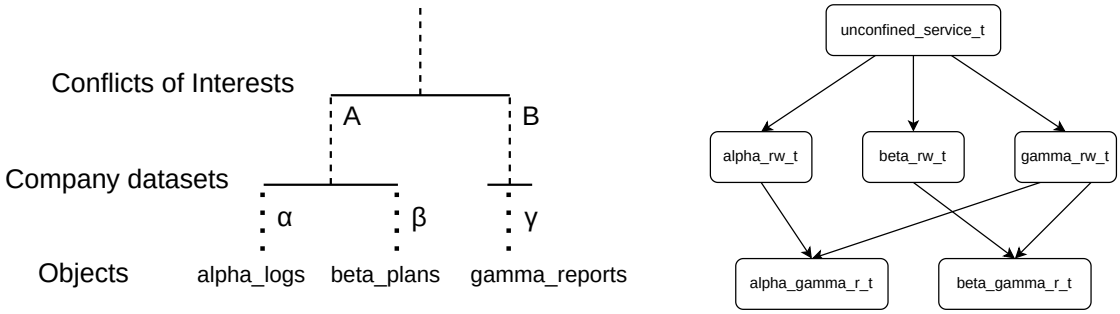
By default, SELinux restricts all actions that aren't granted in some PM. Thus, design of subject PMs must explicitly grant the object operations they shall allow. Six labels are included in the design. `unconfined_service_t` should be noted as a pre-existing label in SELinux for services that haven't been previously labelled.

Label	`alpha_t`	`beta_t`	`gamma_t`	`sanitised_t`
`unconfined_service_t`	r/w	r/w	r/w	r/w
`alpha_rw_t`	r/w		r	r
`beta_rw_t`		r/w	r	r
`gamma_rw_t`	r	r	r/w	r
`alpha_gamma_r_t`	r		r	r
`beta_gamma_r_t`		r	r	r

Table 3: Table of subject labels and their privileges

These labels may be unconventional, for instance, why is it that `alpha_rw_t` can read from `gamma_t`? SELinux is preventative; the standard Wall method of a subject *requesting* permission to access an object or subject is just not possible. As such, the enforcement involves allowing the subject to access anything that it *could*, instantly altering its label afterwards. While a subject with label `alpha_rw_t` *can* read from `gamma_t`, its label will instantly transition to `alpha_gamma_r_t`, revoking its write

access to `alpha_t` forever.



(a) Object structure (b) Subject label transition lattice

Figure 5: SELinux Chinese Wall

4.1.3 CWD Policy Module

The CWD PM would be created following the notion of principle of least privilege. The standard security principle states that a subject should only have access to the required information that is necessary to complete their tasks. The CWD would have a `cwalld_t` label that should suffice to do just that, allow it to operate and nothing more. The nature of a security daemon, ran by root does however lead to the fact that this label would need strong privileges, such as relabelling other processes, effecively meaning it would be able to control the MAC system. This means that keeping the CWD secure would be an important task, if system security was to be upheld to the upmost.

4.2 System Design

4.2.1 Tailing the Audit Daemon

The central idea of the CWD surrounds tailing the log produced by *auditd*. A system daemon enabled by default in SELinux distributions and included in regular distributions, the *Linux Auditing Daemon* is capable of documenting every system call in the system, ranging from reads, writes, SELinux denials and everything else. A rule can be added to `/etc/audit/rules.d/audit.rules`, one of which can make auditd audit every operation in a given directory. This feature would be key in surveilling a certain directory as was outlined as a requirement in *FR2*. The information in the auditd log includes the following information, necessary for the CWD. (See Appendix 11, 12 & 13)

SYSCALL audit:

- Subject process ID
- Subject command
- Subject label

- Subject entrypoint
- Operation
- Operation success

PATH audit:

- Object path
- Object label

AVC audit:

- Specific operation denied

By parsing and combining this information at runtime, subjects in the system can be profiled, and have their operations and history precisely tracked. The logic for restrictions could then be handed to the Chinese Wall enforcement for a decision to be made.

4.2.2 Subject Label Alteration at Runtime

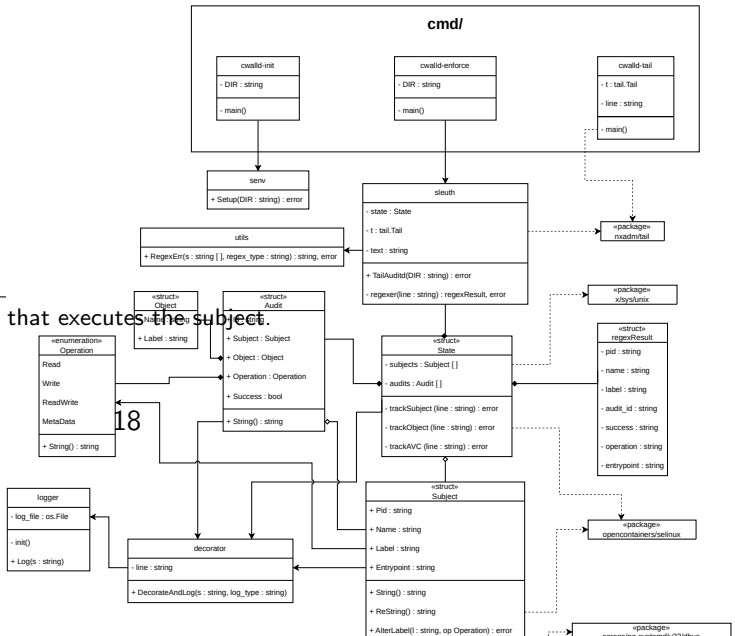
While a subject label can be detected at runtime with the `ps -efZ` command, this label is impossible to change. In SELinux, to change the security context of a subject, the label of the entrypoint[3] must be altered, allowing for the subject to transition into the new label domain once it is restarted. This means the CWD will have to maintain a connection to the system *D-Bus*, to restart daemons at will. Most system daemons are designed with graceful shutdown processes, such that a restart does not constitute a huge loss. The D-Bus restart protocol includes sending a SIGTERM signal to the process, following up with a SIGKILL if the shutdown is not quick enough.

4.2.3 Flowchart

The flowchart (See Appendix 7) represents the central logic loop that surrounds tailing the audit.log file. The design of this flowchart would lead production throughout multiple iterations.

4.2.4 UML Diagram

To assist in development, a UML diagram was produced (full size in Appendix 8). This UML diagram was repeatedly addressed and iterated upon throughout development.



[3]The entrypoint is the binary in the system that executes the subject.

4.3 Assisting Programs

As the CWD will be integrated into the system, there are to be two assisting programs to fulfill *FR1* & *FR10*:

4.3.1 cwalld-init

The CWD *Init* program should set up the audit rule that is required for the CWD to operate. It should also report any issues with the setup process.

4.3.2 cwalld-tail

The CWD *Tail* program should tail and return every line that is logged in `/var/log/cwall/cwall.log`. This allows us to track the cwalld-*enforce* process in real-time, as it tracks operations and alters labels.

5 Implementation

5.1 Virtual SELinux Environment

To develop and test on SELinux, an appropriate SELinux environment is necessary. RHEL was chosen, as it is the most commonly used SELinux distribution. Fedora was also considered; a popular fork of Red Hat skewed towards personal workstations rather than enterprise servers. As the server aspect is more likely to reap results, Red Hat was chosen. As RHEL is an enterprise product, the Red Hat Developer program was joined for free access. Once a key was acquired, a virtual machine was created using KVM, *Quick Emulator* (QEMU) and *Virt Manager* to interface with the virtual machine.

An *ssh reverse tunnel*, allowed the virtual machine to be navigated from the command line of the host machine. RHEL 9 and RHEL 10 were both used for experimentation, RHEL 9 being used after the instance of RHEL 10 was bricked during testing. System specifications can be seen here: 10.

5.2 Technology Selection

5.2.1 Language

Go *(or Golang)* was chosen for the development of the CWD, due to its strong affinity with system-level programming. Go's advantages in systems engineering range from such:

- **Daemon Focus:** Go is very well-suited to daemon programming, remaining unpunishing while giving the developer great versatility and library access.
- **Performance:** As a compiled language, the flexibility to be built into a binary means minimal overhead at runtime. Go promises low-latency, high-performance applications. The freedom to use pointers also allows more precision in containing overhead.
- **Modernity:** Go is a modern alternative to the systems engineering environment. The focus on clean, idiomatic code with statically enforced typing discourages unnecessary complexity and promotes hands-on learning.
- **Familiarity:** Repeated experience working with the language supported the choice and supported steady progress in the venture.

5.2.2 Packages

nxadm/tail

A fork of the deprecated tail package by *hpcloud*, *nxadm* provides a Tail object that can be used to tail a specified file. Tailing a file involves reading every update that occurs, and returning them in real time. It allows a program to closely monitor a file for its own needs. The package leverages *fsnotify* to instantly recognise file updates, also providing truncation/move support, allowing it to follow rotating log files with minimal configuration.

opencontainers/selinux

The *selinux* package provides a direct route for Go make SELinux system calls to the kernel, necessary for operations such as *chcon* (change context, i.e label of an object) and the *-Z* flag for acquiring label information. It also provides native error handling to Go, streamlining usage and debugging.

x/sys/unix

The official Go Project *sys/unix* package introduces a layer of abstraction over both x86 and ARM architecture system call codes, providing a unified interface for detecting system operations.

coreos/go-systemd

go-systemd introduces tools to manage a connection directly to the system D-Bus. This allows direct communication with operations typically managed with systemctl, such as starting and stopping services on a system.

5.3 Version Control

Git was heavily used throughout the project as the primary version control measure. It allows incremental development across multiple devices, which would be critical for splitting development between SELinux and the host machine.

It also kept a backlog of all changes, allowing changes to be reverted if found to be problematic. This gave the project a guarantee, where experimentation could flourish without risk of permanent damage.

5.4 Policy Modules

5.4.1 Object PM Implementation

The SELinux type enforcement system will be briefly covered, as it has a rather esoteric syntax.

```
module beta 1.0;

type beta_t;

files_type(beta_t)
```

Object PMs simply instantiate the domain for the system. The `files_types` macro is shorthand for defining the label globally as a file type.

5.4.2 Subject PM Implementation

PMs had to be created and compiled for $5/6$ of the labels in in Figure 5b. The 6th is the predefined `unconfined_service_t`.

Subject PMs leverage the `policy_module` macro, as they are loadable modules as opposed to the monolithic object modules (See Code Block 1). They must also require every type that they reference. Notice `user_home_t` is needed, to grant the subject navigational privileges across those directories.

```
11 require {
12   type beta_t; type gamma_t; type sanitised_t; type user_home_t; }
```

The following lines are required for all subject PMs, detailing basic daemon behaviour:

```
18 init_daemon_domain(beta_rw_t, beta_rw_exec_t)
19 allow beta_rw_t self:fifo_file rw_fifo_file_perms;
20 allow beta_rw_t self:unix_stream_socket create_stream_socket_perms;
21 allow beta_rw_t user_home_t:dir { search read open write add_name };
```

`init_daemon_domain` is a macro for standard daemons, just shorthand for defining necessary types. Lines 19 & 20 are for communicating with *FIFO* files, D-Bus & the kernel, all necessary for standard operations. Line 21 allows the subjects to navigate directories with the `user_home_dir_t` label. Permission to `add_name` is required as well, as writing files in SELinux periodically requires that permission.

The inclusion of these lines stress that SELinux requires *every* interaction to be granted in the system.

The second lattice layer consisted of the labels:

- `alpha_rw_t`
- `beta_rw_t`
- `gamma_rw_t`

```
allow beta_rw_t beta_t:file { read write getattr open };
allow beta_rw_t gamma_t:file { read getattr open };
allow beta_rw_t sanitised_t:file { read getattr open };
```

In SELinux PMs, `getattr` & `open` must be included to grant read privileges.

The third lattice layer was implemented similarly, towards the specific permissions of the labels:

- `alpha_gamma_r_t`
- `beta_gamma_r_t`

5.4.3 CWD PM Implementation

A policy module had to be constructed to encompass the runtime binary of the CWD. Once all of the functionality of the daemon was complete, SELinux was set to *permissive* mode, where all denials would be logged but not enforced. This meant that all needed privileges were stored, and the `audit2allow` command was leveraged to create a policy module including those privileges as grants. The PM was not complete however, as the final product involved behaviour that would only be executed if a denial was enforced. Such additions to the policy module were found by experimentation, trial and error. (See Appendix Code Block 2)

5.5 Internal Packages

Because the CWD is a low level construction, implementation will naturally include more nuances and development details, as oppose to larger scale system connections.

5.5.1 SEnv (Security-Enhanced env)

Before the CWD can run, the audit rule must be initialised. The SEnv module, called by the cwalld-init binary writes the following rule to `/etc/audit/rules.d/audit.rules`: `-D\n-w "/home/testgrounds/" -p rwa -k cwalld`. The rule tells auditd to delete previous rules, then watch `/home/testgrounds/`, and label all reads, writes and attribute changes with the cwalld key in the audit logs. An `augenrules --load` is then called to apply the rules to the currently running auditd.

5.5.2 Sleuth

The center of the CWD, Sleuth maintains a reference to a single state struct, which holds a slice[4] of subjects, and a slice of audits.

Reading lines from the audit log is the central operation that powers the rest of the CWD. To read the audit lines, the tail must be instantiated. Flags must be set to keep reading lines, and follow/reopen new log rotations. It is also called to skip all previous text in the log before the tail was created. This should stop the CWD from attempting to enforce operations from before its startup.

Once the tail is initialised, reading from it triggers an infinite loop, and returns every new line appended. These lines can then be classified and passed into their respective function.

Before further computation, a brief check is done to see if *setroubleshootd*, or cwalld-enforce itself is involved, the former being an SELinux troubleshooting daemon that conducts checks after denials occur. Given that it is a necessary system process that operates in the enforced directory, it must be exempt from any interference. Cwalld-enforce itself must also be captured early, as if the CWD begins to log itself, a new audit log is created, creating an infinite loop of CWD self computation. Both of these checks call `continue` if found, signalling to skip the rest of the loop and listen for the next log.

As the state struct holds a slice of subjects and audits, using methods means the contents can be altered directly in memory for minimal overhead. The state struct defines the three main methods that parse logs from auditd.

```
77 func (state *State) trackSubject(line string) error { ... }
121 func (state *State) trackObject(line string) error { ... }
181 func (state *State) trackAVC(line string) error { ... }
```

These methods are always called in order due to the consistent order of logging by auditd. Each of these methods use *regular expressions* (regex) to efficiently parse the correct details from the audits. Under the hood, a *Non-Deterministic Finite Automaton* is built, to only accept words in the specified language. The log is fed into this automaton, and the accepted word is returned.

The subject details can be constructed from the various regexes, and then appended to the state. Certain checks have to be made to see if the subject is simply involved in another audit, of which

[4] A slice in Go is a header to an underlying array.

new creation is not required, and another check to see if the same subject has returned with a new PID and label.

`trackSubject()` specifically has 7 regex operations, so logic was abstracted to a seperate `regexer()` function that returns a `regexResult`. `trackObject()` and `trackAVC()` have 3 each, not enough to constitute a separate function.

There is however, another exemption to be wary of. Atomic processes, like *cat* must be skipped entirely. As they are not running subjects, they cannot accumulate a history and be enforced upon. The way to check for atomic processes involves the `selinux.PidLabel()` function, called in `regexer()`. The role is to acquire the label of the logged subject, and whilst the label information is also in the log itself, this function can be used to skip the regex containing its label and check if the process is valid in one swoop. If the function returns an error containing 'no such process', the program propogates its own error to indicate that the process is atomic and to be ignored.

Throughout all programming in the CWD, errors are propagated all the way to the `/cmd/` level, allowing the client code freedom to act accordingly upon errors. This freedom allowed the atomic process error to be updated and returned to `trackSubject()`, such that it could alter its procedure as necessary. If the subject did not instantiate the audit, the PATH log would compute but not finish the audit, successfully skipping over the atomic process.

`trackSubject()` finishes by instantiating an audit. The audit also includes information about operation, and success. To parse the operation, a procedure must be followed to convert it to the correct representation. In the SYSCALL log, the hexadecimal version of the operation flags are found in the a2 segment, and extracted as an integer. Take 241, hexadecimal with 16 bits in the order:

0	0	0	0	0	0	1	0	0	1	0	0	0	0	0	1

As seen, the flags in position 7, 10 and 16 are active. A bitwise *and* operation can be performed with the unix syscall bits to decipher what exact syscalls are happening. The reason the results are asserted to be non-zero is that the result of the and-mask is still a denary number correspondent to the bit that was present. The utils module provides an operation enum to ensure consistent classification of the operations.

```
132 if flags & unix.O_RDWR != 0 { op = utils.ReadWrite } else ...
```

The flags represented above correlate to:

- 0x200 - `O_TRUNC`
- 0x040 - `O_CREAT`
- 0x001 - `O_WRONLY`

As in: create the file if it doesn't exist, truncate the file if it does, and finally write.

Once everything is extracted from the SYSCALL log, the audit is appended to the slice, yet still incomplete. The PATH log contains an audit ID to be matched to the SYSCALL log, and details of the object that was involved. These details are parsed with regex and inserted into the correlating audit in state.

`trackObject()` finishes by passing the required logic to the Subject structs public method `AlterLabel()`.

5.5.3 Subject

The AlterLabel() method on Subject calculates if the label must be changed. As this is a proof of concept, the rules are pre-configured, such that primitive if else statements are suitable to handle label transitions.

Upon detecting the need for a label change, `restartSubject()` is called complete the operation.

`selinux.Chcon()` is used to change the label of the entrypoint to the new label, decided by the previous method. The new label is spliced together with the fields of the old label, except `object_r`, which has to be given to the entrypoint, such that the spawned process can acquire `service_r`. A D-Bus connection is then created with `dbus.NewSystemConnectionContext()`, and used to restart the Daemon.

That involves the full cycle of the CWD.

5.5.4 Decorator and Logger

The `trackAVC()` branch of computation is used solely for logging purposes, and similarly to much of the rest of the program, calls the `DecorateAndLog()` function of the decorator module when logging is required. While not the decorator pattern, this module serves to abstract logic that exists to make the production of the log file more readable. As such, `DecorateAndLog()` finishes by calling `Log()` function of the logger module.

6 Verification & Validation

To provide a strong measure of success of the project, a rigourous testing suite was utilised to its fullest. As the project was under strict success critera, a strong testing suite was crucial to mark them as achieved.

6.1 Testing & Verification

The CWD underwent multiple types of tests, each serving a different primary purpose. Tests included:

- Integration Testing
- Unit Testing
- Benchmarking

6.1.1 Integration Testing

The integration testing suite was the primary source of confirmation during development. The suite consists of 6 simple daemons, written in C. They each attempted to read/write from different objects, some sporadically and some more consistently. Evaluating the success of the CWD involved asserting that the correct labels were assigned under the correct circumstances. Each daemon had a specific label to halt on, ranging every combination necessary for the full Chinese Wall. The logging feature was also heavily utilised, ensuring the CWD was receiving all the information needed, and scrutinising the information produced to trace errors.

6.1.2 Unit Testing

The Go Testing standard library package was used to unit test the program. A testing suite was created for every module, which attempted to push the functionality to its limits. Line coverage was the metric used in unit testing, where the code is evaluated based on how many statements were executed in the testing suite that was ran. Testing was conducted until a high code coverage was achieved across the project, and all major modules were tested extensively.

6.1.3 Benchmarking

Benchmarking (performance testing) was conducted to investigate the speed of the CWD's enforcement. As will be discussed in limitations, the CWD lacks atomic label alterations, meaning that it cannot stop a subject from breaching `CoI` classes if they are instant. Therefore, the speed that the CWD *can* enforce on was tested, using a primitive testing suite written in Go. The suite involves

repeatedly spawning a daemon, that reads from alpha, sleeps, and then writes the information it read to beta. The time to sleep was decremented until it was able to write quick enough that it wasn't denied by the AVC after the CWD manipulated its label. The test ranged every step of $10\mu s$ between $5000\mu s - 1500\mu s$, and marked the exact sleep interval that the information managed to get leaked to beta.

6.2 Validation

Validating the CWD involved returning to the requirements defined in the Specification, and evaluating their success. Int is used to annotate integration here.

Code	Requirement	Validation
FR1	`cwalld` must alter necessary configurations in the system before running.	Int & Unit
FR2	`cwalld` must monitor all operations made by subjects across a given directory.	Int & Unit
FR3	`cwalld` must make decisions based on subject label and object label aligned with the Chinese Wall policy.	Int & Unit
FR4	`cwalld` must alter the labels of subjects at upon call.	Int & Unit
FR5	`cwalld` must be accompanied by policy modules for objects.	Integration
FR6	`cwalld` must be accompanied by policy modules for subjects.	Integration
FR7	`cwalld` should be confined by SELinux with its own custom policy.	Integration
FR8	`cwalld` should run as a service in the system with a service declaration file.	Integration
FR9	`cwalld` should write all operations to a log.	Int & Unit
FR10	`cwalld` should include a binary to follow and display the log in real time.	Integration
FR11	`cwalld` could automatically create necessary policy modules for its runtime.	N/A
FR12	`cwalld` could automatically install necessary policy modules before running.	N/A
FR13	`cwalld` could dynamically enforce the policy given a set of `CoI` classes as input.	N/A
FR14	`cwalld` won't enforce the Chinese Wall policy system-wide.	N/A

Table 4: Validating Functional Requirements

Non-functional requirements NFR1 - NFR4 could be evaluated by their own means. NFR5 (x86/ARM compatibility) was not tested to the fullest, as an ARM machine running SELinux was not obtained throughout the project. While measures were taken, it cannot be surmised that they would be enough to perfect the runtime similar to x86. While the requirement of NFR6 (atomic enforcement) was not realised, the benchmarking suite was established to assess the degree to which it was lacking.

7 Results & Evaluation

The evaluation of the CWD was addresses test results and determines the success of the original project research question and objectives.

7.1 Evaluation Process

The most significant test result to evaluating the Chinese Wall is the integration testing, serving as the answer to the possibility of the Wall's implementation. Once the CWD was working, the integration tests began to work. As more irregularities were detected and patched, the rates of success in the integration testing suite were consistently raised. The integration testing suite works as expected, alongside standard system usage. (See 14, 15)

Performance testing was the next most critical testing process, as it allowed the limitation of enforcement time to be analysed. It was inmportant to disect the speed of the enforcement, brought on by the various layers of processing for the CWD to perform. From testing the range of $3500\mu s - 1500\mu s$, a mean of $??\mu s$ was found. $??\mu s$ provided the quickest enforcement, and $??\mu s$ was the slowest. Standard deviation was used to.

Finally, unit testing was used to ensure robustness of the daemon throughout various different possible exceptional cases. A final code coverage of % was achieved, with the main modules of sleuth and subject at % and % respectively.

7.2 Results of Evaluation

The results of both performance and unit testing will be discussed, before moving to intergration testing, which directly correlates with the answer to the research question & main objective.

The results of the benchmark indicate that the CWD can enforce the Chinese Wall very quickly. While not atomic, the example of a userspace daemon acting upon multiple layers of computation was pushed to its absolute limit, and the program runs with minimal background slowdown.

The high code coverage of unit testing, not only was useful to test but brought minor bugs to light, to be patched. The CWD is proven to be robust by these means.

7.3 Returning to the Objectives

7.3.1 Research Question

While the other tests did not target the research question, the success of the integration tests provide a direct answer to the achieved implementation of the Chinese Wall model. The Chinese Wall was implemented, true to the properties of the Brewer-Nash model and utilising the MAC system of SELinux. The project can be considered a success, as it proved that it is possible to implement the Brewer-Nash model in SELinux.

7.3.2 Objective 1.3.1

The static implementation of the Chinese Wall was completed on schedule, and appropriately guided the success of the following stage.

7.3.3 Objective 1.3.2

The dynamic Chinese Wall was fully implemented and tested, accoring to the functional requirements set out, and is proven to work as intended across multiple circumstances.

7.3.4 Objective 1.3.3

As objective 1.3.3 is mainly a reflective objective, it will be addressed in the following section, reflecting on the challenges and limitations of the Chinese Wall.

8 Discussion & Reflection

8.1 Interpreting the Results

The lack of Chinese Wall inclusion in SELinux is still unclear. As shown, the development of a Chinese Wall in SELinux is certainly possible, with the potential of a thorough security measure being possible with more work (as noted in limitations). The most likely reason for a lack of Chinese Wall attention is a lack of use case. Discussion of the adjacent implementations also included specific problems to be solved, of which SELinux lacks that requirement. Most commonly in practice, SELinux would run as a VM on a cloud server, as an end user product. The nature of conflicts of interest may pose a threat to SELinux users, but the threat model is lacking in scale or necessity.

8.2 Reflection

The main factor holding the project back a lack of deep research of SELinux policy modules, and patience while writing them. Had more resources been scoured early, development would have started later, but on a cleaner and more confident footing.

Having more faith that the project would work out would have also promoted healthy progress, as certain setbacks in the project dimmed the light of the possibility of a successful implementation.

8.3 Challenges

While popular, SELinux severely lacks detailed documentation for developers creating policy modules. This proved it a challenging environment to navigate, along with compilation errors that were punishing and not explanatory, leading to frustration and clouded decision-making.

Another challenge was surrounding the nature of a security daemon. As more features were integrated into SELinux, it became increasingly difficult to understand what part of the program was failing. Errors would seemingly propagate out of thin air, of which the resolution was completely separate from recent changes.

8.4 Limitations

The most crucial limitation of the project involves layers of computation required to enforce label alterations. Due to the nature of the daemon being entirely user-space, the daemon lacks the ability

to atomically alter labels. Unfortunately, it would be rather useless as a security daemon, as it lacks the ability to stop a subject from writing after reading, spreading information. A kernel hook could circumvent this, integrating with the daemon such that the labels can be enforced instantaneously. This would however require kernel level programming, and was deemed to be outside the scope of an undergraduate project.

8.5 Future Work

Future work this would certainly involve kernel level restrictions. eBPF for one, is a kernel technology that was considered if that avenue was to be taken. Kernel integration would surpass the proof of concept of the daemon, and make it a legitimate security daemon capable of enforcing the Brewer-Nash model.

Another avenue of work could involve automatic `CoI` detection and policy installation. It would not pose as much of a challenge/benefit to kernel integration, but would definitely improve quality of the product. The Aggressive Chinese Wall Model could also be addressed, featuring a `CoI` matrix of the CWD's own, instead of the primitive label flow logic build into the current rendition.

9 Conclusion

The conclusion is similar to when a plane lands. You don't rewrite the introduction. You say something like - I addressed the problem outlined in the introduction, and I built some software to do this. I tested the software like this ADD FEW WORDS. Summarize main findings drawn from the project work. Mention the objectives or research questions. Do not repeat points raised in the discussion and reflection Section. If applicable, you can make recommendations. The conclusion should NOT contain any references.

References

[1] D. Brewer and M. Nash, "The chinese wall security policy," in *Proceedings. 1989 IEEE Symposium on Security and Privacy*, pp. 206–214, IEEE Comput. Soc. Press.

[2] "Red hat enterprise linux | red hat partner connect."

[3] D. E. Bell and L. J. Lapadula, "Secure computer systems: Mathematical foundations," Number: MTR2547VOL1.

[4] T. Y. Lin, "Chinese wall security policy-an aggressive model," pp. 282,283,284,285,286,287,288,289–282,283,284,285,286,287,288,289, IEEE Computer Society.

[5] S. N. Foley, "Building chinese walls in standard unixTM," vol. 16, no. 6, pp. 551–563.

[6] Y. Fan, Z. Han, J. Liu, and Y. Zhao, "A mandatory access control model with enhanced flexibility," in *2009 International Conference on Multimedia Information Networking and Security*, vol. 1, pp. 120–124. ISSN: 2162-8998.

[7] R. Sailer, T. Jaeger, E. Valdez, R. Caceres, R. Perez, S. Berger, J. Griffin, and L. van Doorn, "Building a MAC-based security architecture for the xen open-source hypervisor," in *21st Annual Computer Security Applications Conference (ACSAC'05)*, pp. 10 pp.–285. ISSN: 1063-9527.

[8] T.-H. Tsai, Y.-C. Chen, H.-C. Huang, P.-M. Huang, and K.-S. Chou, "A practical chinese wall security model in cloud computing," in *2011 13th Asia-Pacific Network Operations and Management Symposium*, pp. 1–4.

[9] S. Yu, X. Gui, J. Lin, F. Tian, J. Zhao, and M. Dai, "A security-awareness virtual machine management scheme based on chinese wall policy in cloud computing," vol. 2014, no. 1, p. 805923. _eprint: https://onlinelibrary.wiley.com/doi/pdf/10.1155/2014/805923.

[10] Y.-C. Hsiao and G.-H. Hwang, "Implementing the chinese wall security model in workflow management systems," in *International Symposium on Parallel and Distributed Processing with Applications*, pp. 574–581. ISSN: 2158-9208.

[11] L. Herzel and D. E. Colling, "The chinese wall and conflict of interest in banks," vol. 34, no. 1, pp. 73–115. Publisher: American Bar Association.

[12] S. Smalley, "Configuring the SELinux policy,"

[13] K. A. Khan, M. Amin, A. K. Afridi, and W. Shehzad, "SELinux in and out," in *2011 IEEE 3rd International Conference on Communication Software and Networks*, pp. 339–343.

[14] S. Smalley and T. Fraser, "A security policy confguration for the security-enhanced linux,"

[15] P. A. Loscocco and S. D. Smalley, "Meeting critical security objectives with security-enhanced linux,"

[16] L. T. Koehler, "Linux: An operating system," vol. 5, no. 1, pp. 136–141. Num Pages: 6.

[17] B. Sarna-Starosta and S. D. Stoller, "Policy analysis for security-enhanced linux,"

[18] H. James, "85% of all smartphones are powered by linux."

[19] "Can the internet exist without linux? | ZDNET."

[20] "Red hat: Leading the enterprise linux server market."

A Appendix

A.1 cwalld design

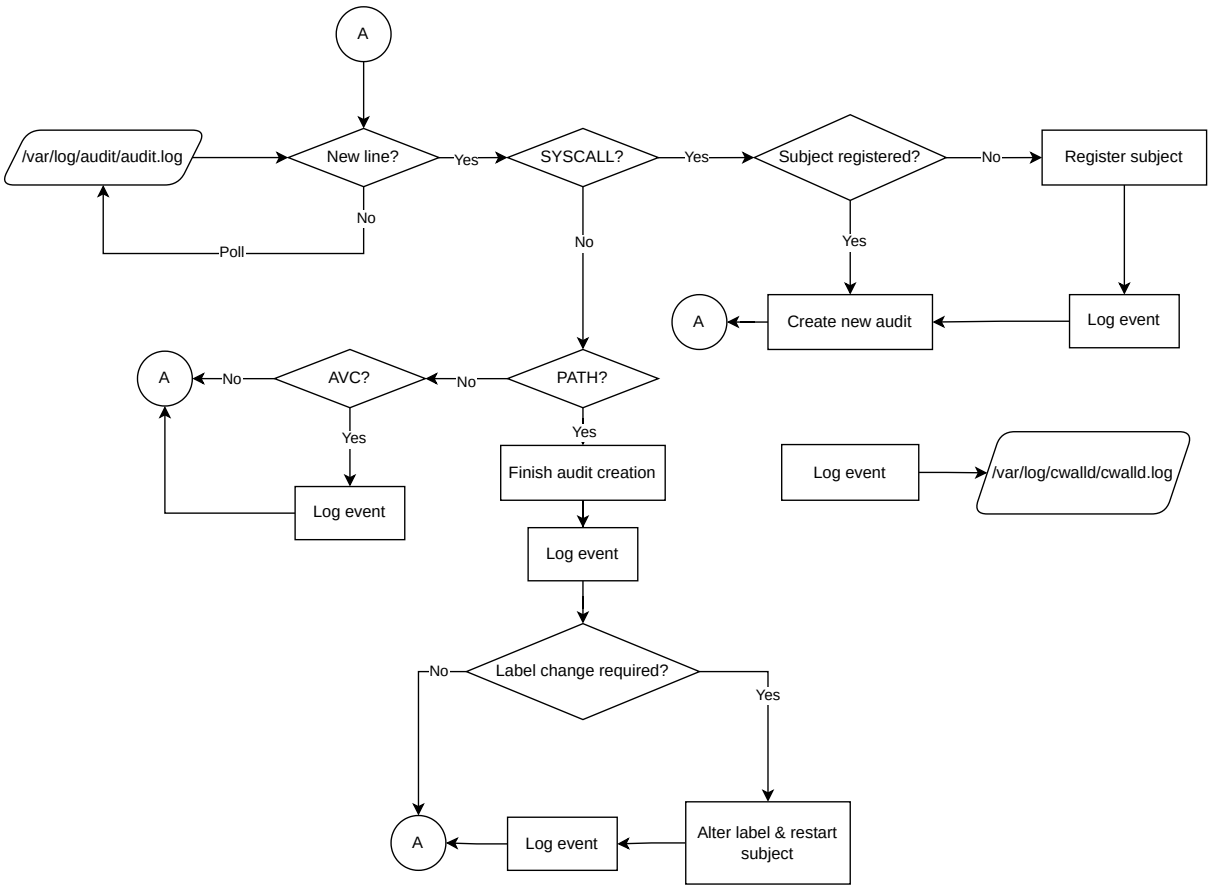


Figure 7: Flowchart

↑ Return to text

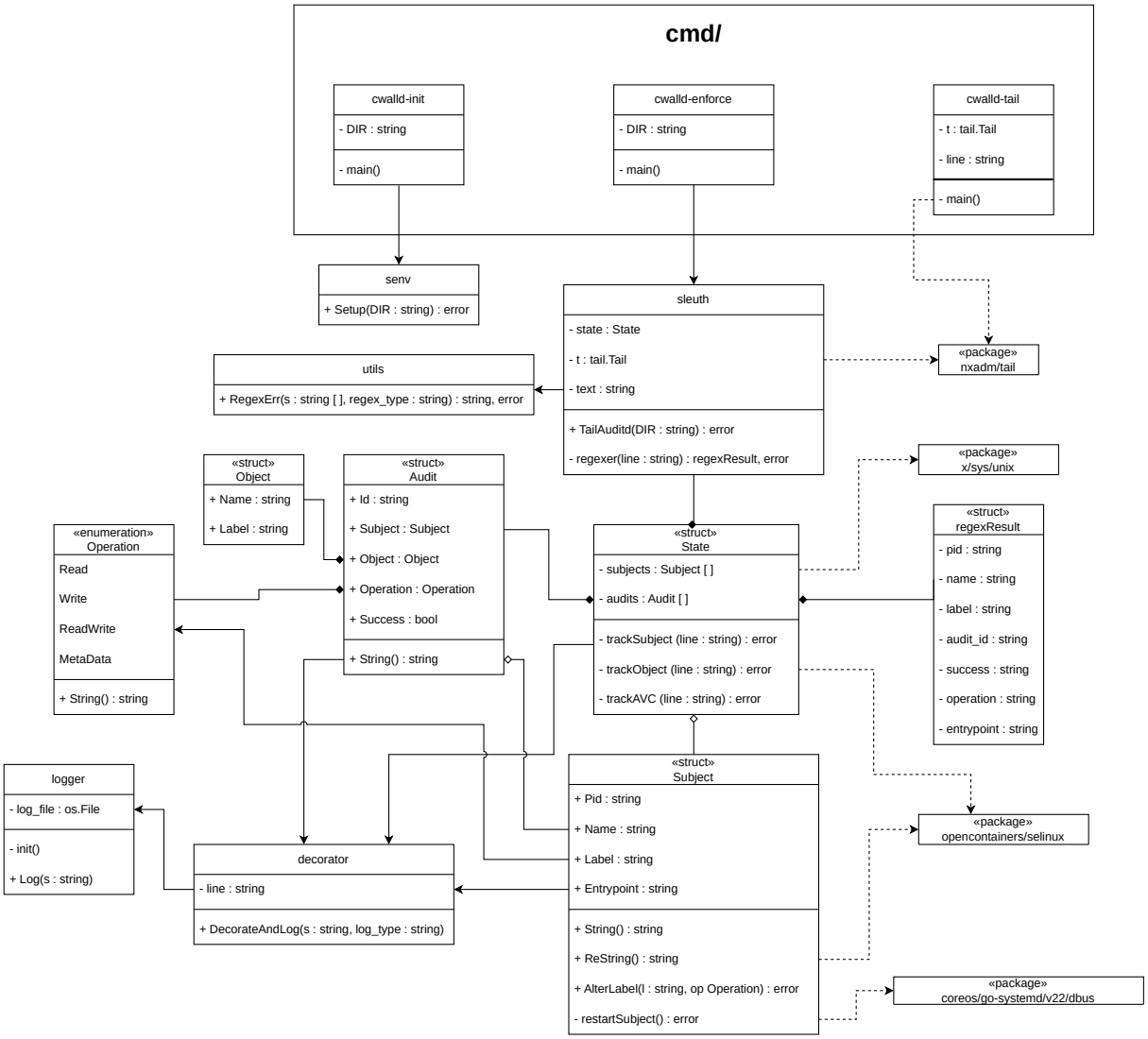


Figure 8: cwalld UML diagram

↑ Return to text

A.2 Red Hat

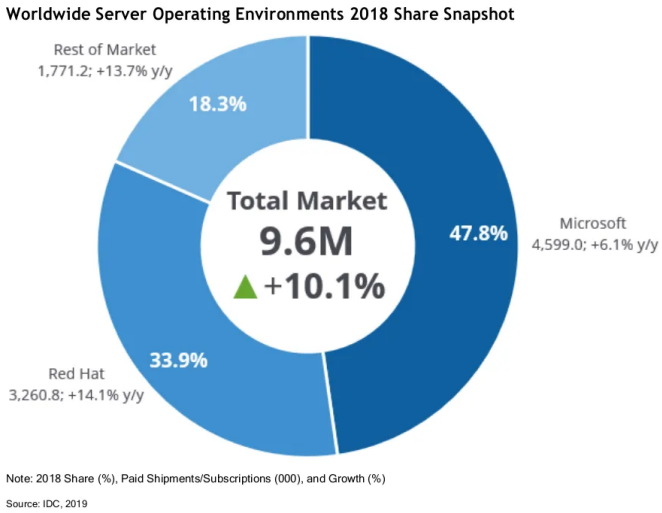


Figure 9: Red Hat statistics

↑ Return to text

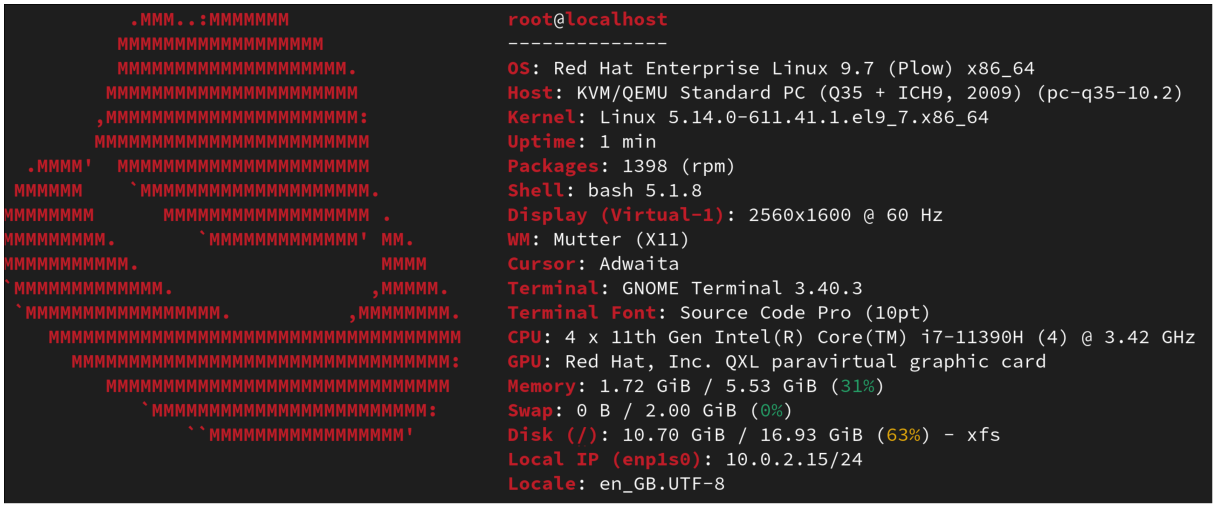


Figure 10: Virtual Machine Red Hat System Specifications

A.3 Auditd logs

```
type=SYSCALL msg=audit(1774217186.548:210): arch=c000003e syscall=257 success=yes exit=3 a0=ffffff9c
a1=402018 a2=241 a3=1b6 items=2 ppid=1 pid=3299 auid=4294967295 uid=0 gid=0 euid=0 suid=0 fsuid=0 egi
d=0 sgid=0 fsgid=0 tty=(none) ses=4294967295 comm="alpha_civild" exe="/usr/local/bin/alpha_civild" su
bj=system_u:system_r:unconfined_service_t:s0 key="cwalld"
```

Figure 11: Example auditd SYSCALL audit

```
type=PATH msg=audit(1774217339.211:13879): item=0 name="/home/testgrounds/objects/alpha_logs" inode=5
8142854 dev=fd:00 mode=0100666 ouid=1000 ogid=1000 rdev=00:00 obj=unconfined_u:object_r:alpha_t:s0 na
metype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
```

Figure 12: Example auditd PATH audit

```
type=AVC msg=audit(1774217334.204:13868): avc:  denied  { read } for  pid=3485 comm="beta_evild" name
="alpha_logs" dev="dm-0" ino=58142854 scontext=system_u:system_r:beta_rw_t:s0 tcontext=unconfined_u:o
bject_r:alpha_t:s0 tclass=file permissive=0
```

Figure 13: Example auditd AVC audit

↑ Return to text

A.4 Policy Modules

```
policy_module(beta_rw, 1.0.0)

########################################
#
# Declarations
#

type beta_rw_t;
type beta_rw_exec_t;

require {
  type beta_t;
  type gamma_t;
  type sanitised_t;
  type user_home_t;
}

init_daemon_domain(beta_rw_t, beta_rw_exec_t)

########################################
#
# beta_rw local policy
#
allow beta_rw_t self:fifo_file rw_fifo_file_perms;
allow beta_rw_t self:unix_stream_socket create_stream_socket_perms;

# cwalld rules
allow beta_rw_t beta_t:file { read write getattr open };
allow beta_rw_t gamma_t:file { read getattr open };
allow beta_rw_t sanitised_t:file { read getattr open };

# navigational policies
allow beta_rw_t user_home_t:dir { search read open write add_name };
```

Code Block 1: "Beta_rw.te"

```
policy_module(cwalld, 1.0.0)

type cwalld_t;
type cwalld_exec_t;

require {
  type proc_t;
  type alpha_rw_exec_t;
  type beta_rw_exec_t;
  type gamma_rw_exec_t;
    type sysfs_t;
    type bin_t;
    type unconfined_t;
    type system_dbusd_t;
    type system_dbusd_var_run_t;
    type unconfined_service_t;
    type init_t;
    type systemd_unit_file_t;
    type unlabeled_t;
    type auditd_log_t;
    type cgroup_t;
    type user_home_t;
  type var_log_t;
  type sanitised_t;
    class process getattr;
    class capability { dac_read_search sys_admin sys_ptrace };
    class file { append execute execute_no_trans getattr map open
       read relabelfrom relabelto watch };
    class dir { getattr search };
    class lnk_file read;
    class filesystem mount;
    class sock_file write;
    class unix_stream_socket connectto;
    class dbus send_msg;
    class service start;
```

```
35 }
36
37 init_daemon_domain(cwalld_t, cwalld_exec_t)
38
39 #============= cwalld_t ==============
40 allow cwalld_t auditd_log_t:dir search;
41 allow cwalld_t auditd_log_t:file { getattr open read watch };
42 allow cwalld_t bin_t:file relabelfrom;
43 allow cwalld_t cgroup_t:dir search;
44 allow cwalld_t cgroup_t:file { open read };
45 allow cwalld_t init_t:dbus send_msg;
46 allow cwalld_t proc_t:filesystem mount;
47 allow cwalld_t self:capability { dac_read_search dac_override
      sys_admin sys_ptrace };
48 allow cwalld_t self:process getattr;
49 allow cwalld_t sysfs_t:file { open read };
50 allow cwalld_t system_dbusd_t:dbus send_msg;
51 allow cwalld_t system_dbusd_t:unix_stream_socket connectto;
52 allow cwalld_t system_dbusd_var_run_t:dir search;
53 allow cwalld_t system_dbusd_var_run_t:sock_file write;
54 allow cwalld_t systemd_unit_file_t:service start;
55 allow cwalld_t var_log_t:dir { create write add_name };
56 allow cwalld_t var_log_t:file { create write open getattr setattr };
57 allow cwalld_t unconfined_service_t:dir search;
58 allow cwalld_t unconfined_service_t:file { open read relabelfrom
      relabelto };
59 allow cwalld_t unconfined_service_t:lnk_file read;
60 allow cwalld_t unconfined_service_t:process getattr;
61 allow cwalld_t unconfined_t:dir search;
62 allow cwalld_t unconfined_t:file { open read };
63 allow cwalld_t unconfined_t:lnk_file read;
64 allow cwalld_t unconfined_t:process getattr;
65 allow cwalld_t user_home_t:dir { getattr search };
66
67 allow cwalld_t file_type:file { relabelto relabelfrom setattr
```

```
getattr };
allow cwalld_t file_type:dir { relabelto relabelfrom setattr getattr };
allow cwalld_t file_type:lnk_file { relabelto relabelfrom setattr getattr };
allow unconfined_t cwalld_exec_t:file { read execute open getattr };
allow cwalld_t domain:file { read open getattr };
allow cwalld_t domain:dir { search getattr };
allow cwalld_t domain:lnk_file read;
allow cwalld_t domain:process getattr;

#============= init_t ==============
allow init_t auditd_log_t:file { open read watch };
allow init_t cwalld_t:dbus send_msg;
```

Code Block 2: *Cwalld_t.te*

```
cal@localhost /usr/local/bin ❯ ls -Z | grep a_
    system_u:object_r:bin_t:s0 alpha_civild
    system_u:object_r:bin_t:s0 alpha_curiousd
    system_u:object_r:bin_t:s0 beta_civild
    system_u:object_r:bin_t:s0 beta_evild
    system_u:object_r:bin_t:s0 gamma_civild
    system_u:object_r:bin_t:s0 gamma_confusedd
```

Figure 14: Before Integration Testing

```
cal@localhost /usr/local/bin ❯ ls -Z | grep a_
     system_u:object_r:alpha_rw_exec_t:s0 alpha_civild
system_u:object_r:alpha_gamma_r_exec_t:s0 alpha_curiousd
      system_u:object_r:beta_rw_exec_t:s0 beta_civild
      system_u:object_r:beta_rw_exec_t:s0 beta_evild
     system_u:object_r:gamma_rw_exec_t:s0 gamma_civild
 system_u:object_r:beta_gamma_r_exec_t:s0 gamma_confusedd
```

Figure 15: After Integration Testing

↑ Return to text

```c
#include <unistd.h>
#include <stdio.h>

FILE *f;

// confused gamma daemon
// it will align itself with gamma, then read from beta, then try to read from alpha as well

int main(void){
  while(1){

    f = fopen("/home/testgrounds/objects/gamma_reports", "r"); // allowed - should have label unconfined_service_t / gamma_rw_t
    sleep(3);
```

```
    if (f != NULL) {
      fclose(f);
    }
    sleep(1);

    f = fopen("/home/testgrounds/objects/beta_plans", "r"); // allowed - should have label beta_gamma_r
    sleep(3);
    if (f != NULL) {
      fclose(f);
    }
    sleep(1);

    f = fopen("/home/testgrounds/objects/alpha_logs", "r"); // denied - not allowed
    sleep(3);
    if (f != NULL) {
      fclose(f);
    }
    sleep(1);

    f = fopen("/home/testgrounds/objects/sanitised", "r"); // allowed
    sleep(3);
    if (f != NULL) {
      fclose(f);
    }
    sleep(1);
  }
}
```

Code Block 3: Gamma Confusedd Daemon